FR-12 – Step 3: Select test cases (best representative of each class)

Input: the equivalence classes in `FR-12_2_equivalence_classes.md`. Method: S04 Domain Testing, Step 3.

- Cover every equivalence class with at least one test case.
- Combine valid classes wherever practical.
- Each invalid test case targets exactly one invalid input class; all other applicable inputs are valid.
- Output classes are recorded on the test cases that produce them.
- These are typical representative values, not boundary-value tests. Boundary analysis belongs to Step 4.

Common setup

ID	Setup
P1	Backend and frontend are running; database is seeded with the specified account `test@eshop.com` / `Test1234!`. Use a separately confirmed admin account for admin-role tests if the project seed provides one; do not assume that the normal account is an admin.
P2	Obtain a fresh, unmodified admin token issued by the server for `admin@eshop.com`; call it `AT`. Log in with `admin@eshop.com` / `Admin123!` (setup guide says `admin123`; documentation conflict, see D7).
P3	Obtain a fresh, unmodified user token issued by the server for the specified account `test@eshop.com` / `Test1234!`, provided that account has the normal `user` role; call it `UT`. If it has a different role, use a confirmed normal-user test account and document its source rather than inventing credentials.
P4	Log in as a normal user (e.g. a freshly registered account), save its token as `UT-deleted`, then delete that user from the admin app.
P5	Not possible: no feature changes a user's role (FR-19 only views/deletes users). TC_33 is Not executed (D10).
P6	Prepare a valid token-shaped string `AT-altered` by changing a character in `AT` after issuance.
P7	Record a known existing protected resource before each write-request rejection test so its data can be checked afterward.
P8	For profile-update tests, authenticate as a normal user and record the current role before the request.

The concrete accounts, token fixtures, API base URL, and UI routes should be adjusted to the running test environment. Where the specification does not define an exact response message or status, the expected result below states the class-level behavior rather than inventing wording.

Valid test cases

TC ID	Test case name	Classes covered	Precondition	Test steps (with data)	Expected result
FR-12_TC_01	Admin logs in successfully	EC_01, EC_03; output EC_52	P1	1. Open the admin web login page. 2. Enter `admin@eshop.com` and `Admin123!`. 3. Submit.	Dashboard is shown.

TC ID	Test case name	Classes covered	Precondition	Test steps (with data)	Expected result
FR-12_TC_02	Admin token accesses admin users with GET	EC_07, EC_09, EC_14, EC_17, EC_19, EC_21, EC_24, EC_30; output EC_46	P1, P2	Send `GET /api/admin/users` with `Authorization: Bearer AT`.	Request succeeds with HTTP 2xx.
FR-12_TC_03	Admin token reads admin orders with GET	EC_24, EC_30; output EC_46	P1, P2	Send `GET /api/admin/orders` with `Authorization: Bearer AT`.	Request succeeds with HTTP 2xx.
FR-12_TC_04	Admin token imports products with POST	EC_24, EC_31; output EC_46	P1, P2	Send a valid `POST /api/admin/import-products` request with `Authorization: Bearer AT` and a valid import request body.	Request succeeds with HTTP 2xx
FR-12_TC_05	Admin token deletes a coupon	EC_25, EC_33; output EC_46	P1, P2; a coupon exists (create one with `POST /api/admin/coupons`, body from API 6.4)	Send `DELETE /api/admin/coupons/:id` for that coupon with `Authorization: Bearer AT`.	HTTP 2xx; the coupon no longer appears in GET /api/coupons.
FR-12_TC_06	Admin token writes products	EC_26, EC_31; output EC_46	P1, P2	Send a valid `POST /api/products` request with `Authorization: Bearer AT` and a valid body.	Request succeeds with HTTP 2xx.
FR-12_TC_07	Admin token writes categories	EC_27, EC_32; output EC_46	P1, P2	Send a valid `PUT /api/categories/:id` request with `Authorization: Bearer AT` and a valid body.	Request succeeds with HTTP 2xx.
FR-12_TC_08	Admin token accesses coupons with GET	EC_28, EC_30; output EC_46	P1, P2	Send `GET /api/coupons` with `Authorization: Bearer AT`.	Request succeeds with HTTP 2xx.
FR-12_TC_12	Public product list without token	EC_35; output EC_51	P1	Send `GET /api/products` without an `Authorization` header.	Request is allowed; HTTP 200.
FR-12_TC_13	Public product detail without token	EC_36; output EC_51	P1	Send `GET /api/products/:id` for an existing product without an `Authorization` header.	Request is allowed; HTTP 200.

TC ID	Test case name	Classes covered	Precondition	Test steps (with data)	Expected result
FR-12_TC_14	Public category list without token	EC_37; output EC_51	P1	Send `GET /api/categories` without an `Authorization` header.	Request is allowed; HTTP 200.
FR-12_TC_15	Admin page opened while logged in	EC_38, EC_40	P1	Log in as admin, then open the admin page URL directly in a new tab.	Admin page is accessible.
FR-12_TC_16	Profile update omits role	EC_43; output EC_57	P1, P3, P8	Send a valid `PUT /api/users/me` request with ordinary profile fields and no `role` field.	Profile update behaves normally; the user's role remains unchanged.

Invalid test cases – profile update role field

TC ID	Test case name	Classes covered	Precondition	Test steps (with data)	Expected result
FR-12_TC_17	User role remains unchanged when role is supplied as admin	EC_44; output EC_57	P1, P3, P8	Send `PUT /api/users/me` with valid profile fields and `"role":"admin"`.	The profile may update, but the stored role remains unchanged and is not elevated to admin.
FR-12_TC_18	User role remains unchanged when another role is supplied	EC_45; output EC_57	P1, P3, P8	Send `PUT /api/users/me` with valid profile fields and a `role` value different from the user's current role (for example, `"role":"admin"` is covered separately in TC_17; use another value only if the API permits sending it).	The stored role remains unchanged; the supplied role is ignored.

Invalid test cases – admin web login

All cases in this section use P1. Keep all fields valid except the single class being targeted.

TC ID	Test case name	Class covered	Test steps (with data)	Expected result
FR-12_TC_19	Normal user attempts admin login	EC_02; output EC_53	Enter the confirmed normal-user account credentials (use `test@eshop.com` / `Test1234!` if that account has the `user` role) on the admin login page and submit.	Login is refused; no admin page is shown and a refusal message is displayed.
FR-12_TC_20	Existing admin email with wrong password	EC_04; output EC_54	Enter `admin@eshop.com` and `Wrong123!` and submit.	Error message; no admin page is shown.

TC ID	Test case name	Class covered	Test steps (with data)	Expected result
FR-12_TC_21	Empty login credential	EC_05; output EC_54	Enter an empty email and a valid password, then submit. (Only the empty-credential class is invalid.)	Error message; no admin page is shown.
FR-12_TC_22	Email does not exist	EC_06; output EC_54	Enter `nobody@eshop.com` and a syntactically valid password, then submit.	Error message; no admin page is shown.

Invalid test cases – protected API authentication and authorization

For each request, use a protected route and a valid request body where the method writes data. For write requests, use P7 and verify the resource is unchanged after rejection.

Precondition: P1, P2, P7 unless stated. TC_29 also needs P6; TC_30 uses P3 instead of P2; TC_32 uses P4 instead of P2; TC_34–TC_35 don't need P7.

TC ID	Test case name	Class covered	Test steps (with data)	Expected result
FR-12_TC_23	Missing Authorization header	EC_08; output EC_47, EC_49, EC_50	Send `POST /api/admin/import-products` with a valid body but no `Authorization` header.	HTTP 401; response contains no protected data/internal details; protected data is unchanged.
FR-12_TC_24	Lower- or mixed-case bearer scheme	EC_10; output EC_47, EC_49, EC_50	Send `POST /api/admin/import-products` with `Authorization: bearer AT` (or mixed-case scheme) and a valid body.	HTTP 401; no protected data/internal details; protected data is unchanged.
FR-12_TC_25	Token supplied without a scheme	EC_11; output EC_47, EC_49, EC_50	Send `POST /api/admin/import-products` with `Authorization: AT` and a valid body.	HTTP 401; no protected data/internal details; protected data is unchanged.
FR-12_TC_26	Different authorization scheme	EC_12; output EC_47, EC_49, EC_50	Send `POST /api/admin/import-products` with `Authorization: Basic AT` and a valid body.	HTTP 401; no protected data/internal details; protected data is unchanged.
FR-12_TC_27	Bearer scheme with empty token	EC_13; output EC_47, EC_49, EC_50	Send `POST /api/admin/import-products` with `Authorization: Bearer` and a valid body.	HTTP 401; no protected data/internal details; protected data is unchanged.
FR-12_TC_28	Random or malformed token	EC_15; output EC_47, EC_49, EC_50	Send `POST /api/admin/import-products` with `Authorization: Bearer not-a-real-token` and a valid body.	HTTP 401; no protected data/internal details; protected data is unchanged.

TC ID	Test case name	Class covered	Test steps (with data)	Expected result
FR-12_TC_29	Token altered after issuance	EC_16; output EC_47, EC_49, EC_50	Send `POST /api/admin/import-products` with `Authorization: Bearer AT-altered` and a valid body.	HTTP 401; no protected data/internal details; protected data is unchanged.
FR-12_TC_30	Valid token has user role	EC_18; output EC_48, EC_49, EC_50	Send `POST /api/admin/import-products` with `Authorization: Bearer UT` and a valid body.	HTTP 403; no protected data/internal details; protected data is unchanged.
FR-12_TC_31	Token is expired, if expiry is implemented	EC_20 (TBD); output EC_47, EC_49, EC_50	Save a fresh admin token at the start of the test session; at the end of the session, send a valid `POST /api/admin/import-products` with it.	Record the result (TBD). If tokens expire: HTTP 401, data unchanged.
FR-12_TC_32	Token owner was deleted	EC_22; output EC_48, EC_49, EC_50	Send a valid `POST /api/admin/import-products` request with `Authorization: Bearer UT-deleted`.	HTTP 404 (D9); data unchanged; no protected details.
FR-12_TC_33	Token owner was demoted from admin	EC_23	Not executed: no role-change feature exists (D10).	—
FR-12_TC_34	Non-existent admin path	EC_29; output EC_48, EC_50	Send a request to a non-existent path such as `GET /api/admin/not-a-real-resource` with a valid admin token and a supported method.	Request is not treated as an allowed admin operation; returns 403 or 404 per Step 2, never exposes protected/internal details.
FR-12_TC_35	Unsupported HTTP method	EC_34; output EC_50	Send an otherwise valid admin request using an unsupported method (for example, `PATCH /api/admin/users`) with a valid admin token.	Any 4xx response; never HTTP 2xx. Response does not reveal protected data or internal details.

Invalid test cases – admin web page and stored token

Precondition: P1 for all cases; TC_37 also needs P3.

TC ID	Test case name	Class covered	Test steps (with data)	Expected result
FR-12_TC_36	Admin page opened without login	EC_39; output EC_55	Clear browser storage/session, then open the admin page URL directly.	Redirected to admin login; no admin data is shown.
FR-12_TC_37	User token stored in admin app	EC_41; output EC_56	Store `UT` in the admin app's expected token-storage location, then open/refresh the admin page.	No admin data is shown; app rejects or redirects from the invalid admin session.

TC ID	Test case name	Class covered	Test steps (with data)	Expected result
FR-12_TC_38	Malformed token stored in admin app	EC_42; output EC_56	Store random text such as `not-a-token` in the admin app's expected token-storage location, then open/refresh the admin page.	No admin data is shown; app rejects or redirects from the invalid admin session.

Coverage check

Every Step 2 class is mapped. TC_09–TC_11 were removed after review (duplicate or undocumented routes); IDs were not renumbered. EC_23 is mapped to TC_33, which is Not executed (D10).

Class ID	Test case(s)	Class ID	Test case(s)	Class ID	Test case(s)
EC_01	TC_01	EC_20	TC_31	EC_39	TC_36
EC_02	TC_19	EC_21	TC_02	EC_40	TC_15
EC_03	TC_01	EC_22	TC_32	EC_41	TC_37
EC_04	TC_20	EC_23	TC_33	EC_42	TC_38
EC_05	TC_21	EC_24	TC_02–TC_04	EC_43	TC_16
EC_06	TC_22	EC_25	TC_05	EC_44	TC_17
EC_07	TC_02	EC_26	TC_06	EC_45	TC_18
EC_08	TC_23	EC_27	TC_07	EC_46	TC_02–TC_08
EC_09	TC_02	EC_28	TC_08	EC_47	TC_23–TC_29, TC_31
EC_10	TC_24	EC_29	TC_34	EC_48	TC_30, TC_32–TC_34
EC_11	TC_25	EC_30	TC_02, TC_03, TC_08	EC_49	TC_23–TC_33
EC_12	TC_26	EC_31	TC_04, TC_06	EC_50	TC_23–TC_35
EC_13	TC_27	EC_32	TC_07	EC_51	TC_12–TC_14
EC_14	TC_02	EC_33	TC_05	EC_52	TC_01
EC_15	TC_28	EC_34	TC_35	EC_53	TC_19
EC_16	TC_29	EC_35	TC_12	EC_54	TC_20–TC_22
EC_17	TC_02	EC_36	TC_13	EC_55	TC_36
EC_18	TC_30	EC_37	TC_14	EC_56	TC_37–TC_38
EC_19	TC_02	EC_38	TC_15	EC_57	TC_17–TC_18

Summary

	Count
Valid test cases	13
Invalid test cases	22
Test cases with an expected result recorded as TBD in Step 2	1 (TC_31)
Total test cases	**35**
Equivalence classes mapped	**57 / 57**

	Count
Equivalence classes with executable coverage confirmed from the supplied routes	**56 / 57** (with EC_23 Not executed because no role-change feature exists)

Notes for review

1. The test data in P1–P8 is a practical setup proposal; adapt credentials, routes, and token fixtures to the actual project.
2. Step 2 marks EC_20 as TBD. TC_31 records the observed behavior instead of assuming the implementation has token expiry.
3. Step 2 allows either 403 or 404 for a non-existent admin path; TC_34 preserves that decision.
4. EC_49 requires a write request to be rejected without changing protected data. The invalid authentication/authorization cases use a protected write endpoint and include a data-integrity check.
5. Step 3 uses typical values only. Boundary values and systematic edge testing are reserved for Step 4.
6. Coupon writes use the documented `/api/admin/coupons` routes; `/api/coupons` is covered by `GET` only (TC_08), per review decision.